Relatório de Auditoria de Segurança — Painel de Estudos v1.8

Data: 13/11/2026

Escopo

Atualização da cópia pública painel-de-estudos da v1.7 para a v1.8 (dados fictícios), antes do push: backend FastAPI + SQLAlchemy + SQLite, frontend React + Vite + TypeScript, Dockerfile, docker-compose, bundle compilado, prints e guia em PDF. Foco no que mudou desde a v1.7: a área de cursos e certificados (rotas, migração, telas), paginação, Cancelar do cronômetro e exclusão de AAC.

Stack detectada e como cada categoria foi mapeada

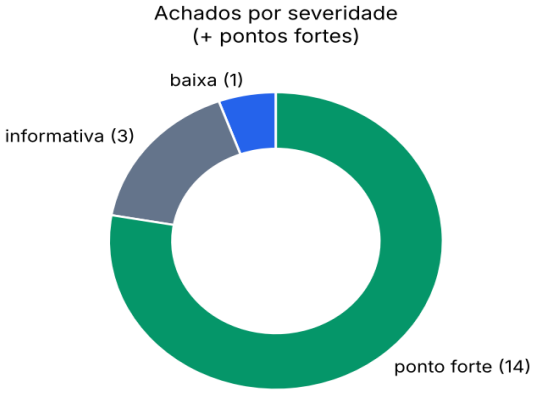
App local de um usuário, sem autenticação (SPEC D1), porta presa a 127.0.0.1. (1) Isolamento: não há tenant; foi auditado o isolamento de rede (loopback, Host, CORS, CSRF). (2) Permissão no navegador e (3) IDOR: não há papéis nem donos; todos os routers foram percorridos para confirmar. (4) Chaves: código, compose, .env.example, histórico git e bundle. (5) XSS: sinks no React e renderização da saída do modelo. Além das cinco, foram auditados cabeçalhos HTTP, dependências (pip-audit, npm audit) e o container.

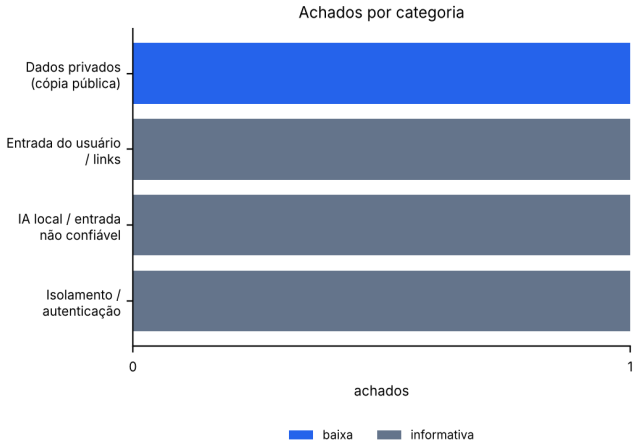
Método

Leitura de código + testes contra o app rodando (curl): Host forjado, POST text/plain, POST com Origin e Sec-Fetch-Site de outro site nas rotas novas, travessia de caminho na pasta de materiais e nos arquivos estáticos; os testes automáticos de travessia e de escrita de outro site; grep de segredos e dados pessoais; OCR dos prints (ampliados, com controle) e texto do PDF; pip-audit e npm audit.

Resumo executivo

Severidade	Total	Corrigidos	Abertos	Aceitos
CRÍTICA	0	0	0	0
ALTA	0	0	0	0
MÉDIA	0	0	0	0
BAIXA	1	1	0	0
INFORMATIVA	3	0	0	3
PONTO FORTE	14	—	—	—





4 achados: nenhum crítico, alto ou médio. As referências ao processo privado (baixa) foram corrigidas antes da publicação. **Nenhum aberto**; 3 informativos aceitos por decisão do SPEC (links digitados, texto da aula no modelo local, sem login).

Pontos fortes

✔ **Porta só no loopback** — docker-compose.yml publica 127.0.0.1:8000; nada exposto na rede.

✔ **Host validado (DNS rebinding)** — Host: evil.com → 400 contra o app rodando.

✔ **Escrita só da própria página, rotas novas incluídas** — POST /api/courses com Origin externo → 403; DELETE /api/courses/{id} com Sec-Fetch-Site cross-site → 403; PATCH de aula em text/plain → 422.

✔ **Faculdade protegida das rotas de cursos** — Toda rota de curso, módulo e aula confere que o registro é de um curso: DELETE /api/courses/1 (a graduação) → 404; disciplina por /courses/modules e tema por /courses/lessons → 404. Sem isso, apagar um curso poderia apagar a graduação inteira.

✔ **AAC lançada uma vez** — POST /api/courses/{id}/acc: 201 na primeira, 409 na segunda; só com o curso concluído.

✔ **Migração só acrescenta** — f2c8e1a7b934 só adiciona colunas e uma chave estrangeira com SET NULL; nenhum dado existente muda.

✔ **Links dinâmicos controlados** — Curso só https://; Notion sempre https://www.notion.so/<id>; rel="noopener noreferrer" nos links externos.

✔ **Cabeçalhos de segurança** — CSP só 'self', frame-ancestors 'none', X-Frame-Options DENY, nosniff, no-referrer (conferido em /cursos).

✔ **Sem SQL cru com f-string** — Acesso ao banco pelo ORM; a migração usa o batch do Alembic.

✔ **Sem sinks de XSS** — Nenhum dangerouslySetInnerHTML, innerHTML, eval, new Function ou window.open nas telas novas; nome, plataforma e texto da aula renderizados como texto.

✔ **Sem segredos** — Busca por padrões (ntn_, secret_, sk-, ghp_, AKIA): nenhum resultado no que mudou.

✔ **Arquivos estáticos seguros** — /..%2f..%2fetc%2fpasswd devolve o index.html.

✔ **Dependências limpas** — pip-audit: nenhuma vulnerabilidade; npm audit: 0.

✔ **CI** — GitHub Actions em todo pull request: ruff + pytest (115 testes) e tsc + vitest (20) + build.

Pontos fracos (riscos centrais)

1. O app confia na rede: sem login, a defesa contra páginas maliciosas no navegador é a porta no loopback + Host validado + bloqueio de escrita vinda de outro site (#4).

2. A cópia pública nasce da privada: sem a limpeza (#1), dados e documentos privados iriam junto.

3. Faculdade e cursos usam as mesmas tabelas: a trava das rotas de cursos é o que protege a graduação (ver pontos fortes).

Categorias do prompt que não se aplicam

1. Banco sem tranca (tenant) — App de um usuário só, sem contas nem tenants (SPEC D1).

2. Permissão no navegador — Não existem papéis no frontend nem no backend.

3. IDOR — As rotas novas por ID (cursos, módulos, aulas, AAC) foram percorridas: todo objeto pertence ao único usuário; a separação entre faculdade e cursos foi conferida (ver pontos fortes).

4. **Chaves expostas** — Aplicável e verificado: nenhum achado (ver pontos fortes).
5. **XSS** — Aplicável e verificado: nenhum achado (ver pontos fortes).

Achados detalhados

Dados privados (cópia pública)

Sev.	Arquivo:linha	Descrição	Status
BAIXA	frontend/src/components/panel/TimerCard.tsx, frontend/src/components/ui/button.tsx, SPEC.md	**#1 Referências ao processo privado na atualização exportada** A exportação da versão privada trouxe dois comentários que citam números de pedidos ao design system (documentos que não fazem parte da cópia pública), o nome do dono na linha de versão do SPEC e o caminho de uma imagem de proposta que fica fora da cópia pública. *Correção:* Comentários reescritos sem os pedidos; SPEC com "(seu nome aqui)" e sem o caminho da imagem. Conferido por grep (nome, instituição, caminhos, e-mail, links pessoais), texto do PDF e OCR dos 20 prints novos ou refeitos (ampliados 2×, com controle: o título foi lido em 20 de 20).	corrigido

Entrada do usuário / links

Sev.	Arquivo:linha	Descrição	Status
INFORMATIVA	backend/app/courses.py, frontend/src/pages/CourseDetailPage.tsx	**#2 Links e caminho do certificado digitados pelo dono** O link do curso só aceita https:// (no servidor e na tela) e abre com rel="noopener noreferrer". Do link do Notion o servidor guarda só o id de 32 caracteres; o link mostrado é sempre https://www.notion.so/<id>, mesmo se colarem outro domínio. O caminho do certificado é só texto: o servidor nunca abre esse arquivo. *Correção:* Nenhuma ação agora.	aceito

IA local / entrada não confiável

Sev.	Arquivo:linha	Descrição	Status
INFORMATIVA	backend/app/agent, backend/app/cards.py	**#3 Texto da aula vai para o modelo local (prompt injection)** Igual aos temas da faculdade: o texto colado numa aula vira material das questões e dos cards. O modelo não tem ferramentas nem acesso à rede ou a arquivos; a saída é validada por schema Pydantic e mostrada como texto. Prints e o resumo dos números continuam só no modelo local (SPEC D17, D25, D36). *Correção:* Nenhuma ação agora.	aceito

Isolamento / autenticação

Sev.	Arquivo:linha	Descrição	Status
INFORMATIVA	docker-compose.yml	**#4 Sem login, por decisão do SPEC (D1)** Igual à v1.7: a barreira é a porta presa ao loopback + validação de Host + bloqueio de escrita vinda de outro site, conferido também nas rotas de cursos. *Correção:* Nenhuma ação agora.	aceito

Trechos de código (antes da correção)

#1 · frontend/src/components/panel/TimerCard.tsx, frontend/src/components/ui/button.tsx, SPEC.md

```
// (o Select do DS ainda não tem grupos: pedido 07; ...)
Version 1.8 · ... · Owner: <dono>
```

#2 · backend/app/courses.py, frontend/src/pages/CourseDetailPage.tsx

```
url javascript:alert(1) → 422
notion_page https://evil.com/<id> → guardado só o <id>
```

#3 · backend/app/agent, backend/app/cards.py

```
body: { topic_id: l.id, n_options: nOptions }
```

#4 · docker-compose.yml

```
- "127.0.0.1:8000:8000"
```

Recomendações priorizadas

P2 — Depois do docker compose up --build, conferir que a migração da v1.8 rodou (o grupo "Cursos e certificados" aparece) e que a faculdade continua igual.

P3 — Ativar Dependabot ou rodar npm audit e pip-audit a cada atualização.

P3 — A cada nova versão pública: repetir grep + OCR dos prints e deixar fora os documentos internos.

Checklist antes do deploy

Item	Situação
Rodei o prompt e li o PDF inteiro	Para o dono fazer: ler este relatório.
Todo endpoint com ID valida o dono	Não se aplica: um usuário só (a separação entre áreas foi conferida).
Toda listagem filtra por usuário/tenant	Não se aplica: sem tenants.
Permissão escondida no front é conferida no servidor	Não se aplica: sem papéis.
Nenhum segredo no código, bundle, compose ou CI	OK: verificado.
Busca no histórico git e revogação	OK: o histórico público só tem as versões fictícias; nada a revogar.
Input validado antes de virar HTML	OK: React escapa; sem sinks de HTML; links dinâmicos só https.
Supabase: RLS e service_role	Não se aplica: SQLite local.
Achados viraram issue ou advisory	Achados acionáveis corrigidos; nenhuma issue em aberto.

Issues para o GitHub

Só os achados ainda abertos viram issue; os corrigidos já estão nesta versão. Nenhum achado é explorável a ponto de pedir advisory privado.

Nenhuma issue em aberto: todos os achados acionáveis foram corrigidos nesta versão.